

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)*

Assessment Tool Weightage: 35%

Student Details

Name : Lekkala Dattu Kumar
Register Number : 192324141
Department : AI&DS

QUESTIONS: 5

Total Marks:100

1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux.

Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.

2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.
3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.
5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

Code of Conduct:

I CK AFROZ (192311108) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning

Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, well-structured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity difficult to understand

		d			
--	--	---	--	--	--

ASSESSMENT TOOL 3 – CASE STUDY

Answered Questions – CO4: Network Security Testing

Course: ITA14 – Ethical Hacking

Note: The answers below are written as an authorized, controlled security assessment methodology. Any exploitation or wireless testing should be performed only with explicit permission and in an isolated test environment.

1. Web Server and Web Application Security Assessment

Analysis: The case indicates several related attack vectors: suspicious HTTP requests suggest directory discovery and attempts to reach hidden administrative or backup locations; malicious scripts in input fields indicate possible Cross-Site Scripting (XSS); and the outdated Apache/software stack creates exposure to publicly known vulnerabilities. The absence of a Web Application Firewall (WAF) removes an important detection and filtering layer. Unauthorized transactions and abnormal account activity also make authentication, authorization, session management, and transaction integrity important areas of assessment.

Reconnaissance / Identification: Reconnaissance should begin with written authorization, a defined scope, and a safe test window. In Kali Linux, passive information gathering can identify the application's domains, technologies, exposed services, and publicly visible information. Tools such as Nmap can then be used in an authorized environment to identify reachable hosts, ports, and service versions. WhatWeb can help identify web technologies and frameworks, while Burp Suite can be configured as an intercepting proxy to understand application routes, parameters, cookies, and security headers.

Scanning / Validation: For vulnerability scanning, the analyst should compare identified software versions against trusted vulnerability information and use scanners such as Nikto and Nmap's vulnerability-oriented scripts where appropriate. Burp Suite can be used to crawl and inspect the application, review requests and responses, and identify issues such as missing security headers, weak session controls, reflected input, and unsafe parameters. Scanner findings must be manually validated to reduce false positives and to avoid causing service disruption.

Controlled Exploitation / Testing: Exploitation should be performed only against an approved test instance or explicitly authorized production scope. Rather than launching destructive attacks, the analyst can validate findings with harmless proof-of-concept inputs. For example, an input field suspected of XSS can be tested with a non-destructive marker, and an access-control issue can be verified by checking whether a test account can reach a resource outside its authorized role. If a known vulnerable software component is identified, the assessment should demonstrate risk using a controlled lab reproduction or vendor-approved validation rather than uncontrolled exploitation.

Mitigation / Defense: A layered defense strategy should include: (1) patching and supported versions of

Apache, the operating system, libraries, and frameworks; (2) disabling unnecessary modules, services, directory listing, and default accounts; (3) least-privilege service accounts and strong file permissions; (4) secure coding with server-side input validation, parameterized database queries, context-aware output encoding, CSRF protection, and strong authorization checks; (5) secure cookies using Secure, HttpOnly, and appropriate SameSite settings; (6) a WAF with logging and carefully tuned rules; (7) network segmentation and firewall restrictions; (8) centralized logging and alerting for suspicious requests and account activity; (9) MFA for privileged and high-risk actions; (10) backups and tested incident-response procedures. Together these controls reduce both the probability and impact of

a successful attack.

2. SQL Injection and Cross-Site Scripting Security Audit

Analysis: SQL injection occurs when untrusted input is incorporated into a database query without safe parameterization. In this case, an attacker could potentially manipulate account-related requests to alter query logic and retrieve or modify information. XSS occurs when attacker-controlled content is returned to users without appropriate output encoding or sanitization. A stored XSS issue is particularly serious because malicious content can be saved and subsequently executed in pages viewed by other users. The exposed database errors further help attackers understand internal structures and should therefore be removed from production responses.

Reconnaissance / Identification: A safe audit begins by mapping the application's authentication, account, transaction, and profile functions. Burp Suite can capture requests, identify parameters, replay test requests, and compare normal responses with carefully controlled test inputs. The tester should look for changes in response behavior, database-related error messages, unexpected status codes, and evidence that input is being interpreted as part of a query rather than as data. For XSS, inputs should be traced from source to sink and tested using benign markers in a controlled environment.

Scanning / Validation: SQLmap can be used in an authorized lab after Burp Suite identifies a candidate parameter. The tester should first verify the finding manually, then use SQLmap with conservative, non-destructive settings to confirm whether the parameter is injectable and determine the affected database technology when necessary. The objective is validation and risk measurement, not extraction of real customer records. If the test environment contains synthetic data, controlled evidence can be collected to demonstrate the security impact.

Controlled Exploitation / Testing: For XSS, Burp Suite can be used to modify parameters and inspect whether supplied content is reflected or stored. The analyst should determine the context in which the data is rendered—HTML, attribute, JavaScript, URL, or another context—because the correct defense depends on the output context. The finding should be documented with the affected endpoint, parameter, user role, persistence behavior, and affected users, while avoiding harmful payloads or unauthorized execution.

Mitigation / Defense: The CIA impact is significant. Confidentiality can be violated when SQL injection exposes customer, account, or database information. Integrity can be violated when unauthorized database changes or transaction manipulation become possible, and XSS can alter what users see or cause actions to be performed in their browser context. Availability can be affected by expensive or malformed database operations, application errors, or abuse of application functionality. Mitigation should include parameterized queries/prepared statements, allow-list validation, safe ORM usage, generic production error messages, centralized logging, context-aware output encoding, a strong Content Security Policy, secure cookies, CSRF protection, session rotation after authentication, short session lifetimes for sensitive operations, MFA, rate limiting, least-privilege database accounts, WAF rules, security testing in CI/CD, and regular penetration testing.

3. Evil Twin Attack and Wireless Security

Analysis: An Evil Twin attack creates a fraudulent wireless access point that imitates the legitimate SSID. Employees may connect because the name appears familiar, especially when devices automatically reconnect to remembered networks. Once connected, the attacker can position the device between the user and network services, collect network metadata, and present fraudulent authentication pages. Credentials are at risk when users submit them to an attacker-controlled page or when applications fail to enforce strong certificate validation. The reported slow performance and unusual login prompts are therefore useful indicators of a rogue wireless environment.

Reconnaissance / Identification: In an authorized assessment, Aircrack-ng tools can help survey nearby wireless networks, compare BSSID/MAC addresses associated with the same SSID, observe channel usage, and identify suspicious or duplicate infrastructure. The objective is to distinguish legitimate access points from unexpected transmitters. Wireshark can then capture traffic from a controlled test network and help analyze authentication behavior, DNS activity, DHCP information, retransmissions, and other indicators that support the investigation. Packet captures should be collected only where authorization exists and should be protected because they may contain sensitive information.

Scanning / Validation: The WPA2-PSK configuration has important weaknesses if a shared password is weak, reused, or widely distributed. PSK authentication does not by itself prove that a user has connected to the genuine corporate access point. Users can therefore be susceptible to rogue infrastructure and credential phishing. A stronger design uses enterprise authentication such as WPA2-Enterprise or WPA3-Enterprise with 802.1X and a RADIUS-backed identity system. Proper certificate validation on clients is essential so that users do not accept fraudulent authentication servers.

Controlled Exploitation / Testing: Countermeasures should include enterprise wireless authentication, strong unique credentials, protected management frames where supported, wireless intrusion detection/prevention, monitoring for duplicate SSIDs and unexpected BSSIDs, network segmentation, client isolation where appropriate, and continuous logging of wireless events. Security teams should investigate repeated authentication prompts, sudden BSSID changes, and unusual channel behavior. Users should be trained never to bypass certificate warnings or enter credentials into unexpected captive portals and should report suspicious Wi-Fi behavior immediately.

4. Wireless-to-Web Application Penetration Testing

Analysis: The attack chain begins with compromise of the weakly protected Wi-Fi network. After obtaining network access, the attacker performs reconnaissance to discover hosts and services. The employee management system is then identified as a web target. Weak authentication and session management provide opportunities to access functions without adequate authorization. If application vulnerabilities also exist, the attacker may move from a normal user context to unauthorized administrative functionality and eventually reach confidential employee data. This illustrates why wireless security and application security must be assessed together.

Reconnaissance / Identification: During reconnaissance, the tester should establish the approved IP ranges, wireless scope, application URLs, and test accounts. Aircrack-ng can be used in a controlled lab to assess wireless configuration and discover authorized access points. Nmap can enumerate hosts and services reachable from the test network. Burp Suite can map the web application's endpoints, parameters, authentication flows, cookies, and session behavior. The tester should document the attack surface before attempting exploitation.

Scanning / Validation: Scanning and validation should focus on authentication, authorization, session management, input validation, exposed services, and security headers. Burp Suite can compare requests made by different test roles to determine whether authorization is enforced server-side. A test account with limited privileges can be used to verify that administrative endpoints cannot be reached simply by changing a URL or request parameter. Session identifiers should be checked for secure cookie flags, rotation after login, expiration, and invalidation after logout.

Controlled Exploitation / Testing: Exploitation in the assessment should use controlled proof-of-concept steps. If a privilege-escalation flaw is identified, the tester can demonstrate access to a harmless test record or a non-sensitive administrative function rather than extracting real employee information. Evidence should include the original privilege, the vulnerable endpoint, the authorization failure, and the resulting impact. The chain should be reported as a sequence: wireless weakness □ internal network access □ service discovery □ web application weakness □ authorization/session failure □ attempted privilege escalation □ data exposure.

Mitigation / Defense: Defense-in-depth requires strong WPA2/WPA3-Enterprise authentication, long unique credentials, protected management frames, wireless IDS/IPS, VLAN segmentation, firewall rules between wireless clients and sensitive systems, and NAC where appropriate. At the application layer, implement MFA, server-side authorization on every sensitive operation, secure session management, strong password hashing, CSRF protection, input validation, output encoding, secure cookies, rate limiting, logging, and alerting. Sensitive databases should use least-privilege accounts and encryption. Regular vulnerability scanning, code review, penetration testing, patch management, and incident-response exercises should cover both the wireless and web layers.

5. Wireless Deauthentication Attack and Mitigation

Analysis: A deauthentication attack abuses the management-frame behavior of Wi-Fi networks. An attacker transmits forged deauthentication management frames that appear to come from a legitimate access point or client, causing stations to disconnect and attempt to reconnect. Repeating this process creates a denial-of-service condition. The core weakness in older wireless deployments is that management frames were not always cryptographically protected, so a receiver could accept forged frames that looked legitimate.

Reconnaissance / Identification: In a controlled lab, the attack can be studied without targeting real users. Aircrack-ng tools can be used to monitor wireless management traffic and demonstrate how clients respond to deauthentication events. Wireshark can capture and filter management frames, allowing the analyst to observe repeated deauthentication events, source/destination addresses, timing, channels, and abnormal frame rates. The simulation should use isolated test access points and test clients, with a defined stop condition so that the experiment cannot disrupt production networks.

Scanning / Validation: The direct impact is loss of availability. Users may repeatedly lose connectivity, applications can experience timeouts, voice/video sessions can drop, and productivity can fall sharply during peak periods. Repeated reconnect attempts can also increase congestion and obscure the source of the disruption. From an incident-response perspective, the organization should correlate wireless controller logs, AP events, IDS/IPS alerts, and packet captures to distinguish deliberate deauthentication from ordinary RF interference or equipment faults.

Controlled Exploitation / Testing: Effective mitigation includes Protected Management Frames (PMF/802.11w), preferably required where compatible; WPA3 deployments where appropriate; modern enterprise authentication; wireless intrusion detection/prevention; AP/controller firmware updates; RF monitoring; and segmentation. Monitoring should alert on abnormal rates of deauthentication/disassociation frames and repeated events associated with a particular location or device. Network teams should also maintain redundant coverage and capacity so that a localized wireless incident has less operational impact.

Mitigation / Defense: User awareness remains important but should not be the primary control for a protocol-level attack. Employees should know how to report repeated disconnections and suspicious network behavior, while administrators should have a documented wireless incident-response process. Combining secure protocols, protected management frames, monitoring, configuration hardening, and rapid response provides a stronger defense than relying on a single control.